

Institución: Terciario Urquiza

Carrera / Curso: Desarrollo de software / 3 1ra

Materia: Redes

Docente:Luciana

becker

Integrantes: Esnoz Gustavo

Fecha de entrega: Octubre de 2026

Trabajo de investigación: preguntas 1 a 23 con bibliografía consultada.

Contenido

Sección	Preguntas
A. Conceptos generales	1 a 3
B. Amenazas y ataques	4 a 8
C. Herramientas y protección	9 a 13
D. Diseño de redes seguras	14 a 16
E. Gestión de incidentes y normativa	17 a 23
Bibliografía	Fuentes consultadas [1] a [40]

Nota: los números entre corchetes, como [6], remiten a la bibliografía del final.

• ¿Qué se entiende por seguridad en redes informáticas y por qué es cada vez más relevante?

La **seguridad en redes** es el conjunto de políticas, prácticas, procedimientos y tecnologías que protegen la infraestructura de comunicaciones (equipos, enlaces, protocolos, servicios y los datos que circulan por ellos) frente al acceso no autorizado, el uso indebido, la modificación, la interrupción o la destrucción. Abarca controles técnicos (firewalls, cifrado, segmentación, monitoreo), administrativos (políticas, normas, gestión de incidentes) y humanos (capacitación y concientización). El marco NIST CSF 2.0 la organiza en funciones: gobernar, identificar, proteger, detectar, responder y recuperar [1].

Su relevancia crece por varios factores combinados:

- **Superficie de ataque en expansión:** teletrabajo, nube, dispositivos IoT, billeteras virtuales y pagos con QR hacen que casi toda actividad dependa de una conexión.
- **Motivación económica y profesionalización del delito:** el ransomware como servicio (RaaS) permite que atacantes con poco conocimiento técnico alquilen la infraestructura de grupos criminales.
- **Impacto concreto en Argentina:** el informe de SCILabs sobre el primer semestre de 2025 ubicó al país cuarto en incidentes de ransomware de Latinoamérica (10,77 % de los casos regionales), con la manufactura como sector más afectado [2].
- **Dependencia crítica:** hospitales, energía, bancos y gobierno funcionan sobre redes; una interrupción afecta a la sociedad, no solo a una empresa (ver casos en preguntas 4 y 21).

- **Tríada CIA (Confidencialidad, Integridad, Disponibilidad) con un ejemplo propio para cada pilar**

La tríada CIA es el modelo base de la seguridad de la información; toda medida de protección busca preservar al menos uno de estos tres pilares [1][3].

Pilar	Definición	Ejemplo propio	Control típico
Confidencialidad	Solo accede a la información quien está autorizado.	Un estudiante accede al sistema de calificaciones con su usuario; ningún otro alumno puede ver sus notas. Si alguien las ve usando una contraseña filtrada, se violó la confidencialidad.	Cifrado, control de accesos, MFA

Pilar	Definición	Ejemplo propio	Control típico
Integridad	La información no se altera de forma no autorizada ni accidental; es exacta y completa.	Una transferencia bancaria de $10.000 llega como $10.000. Si un atacante modificara el monto en tránsito, se violaría la integridad.	Hashes, firmas digitales, control de versiones
Disponibilidad	Los sistemas y datos están accesibles cuando se los necesita.	Una tienda online que sigue operando el día de una promoción masiva. Un ataque DDoS que la deja fuera de servicio viola la disponibilidad.	Redundancia, backups, anti-DDoS, UPS

- **¿Qué diferencia hay entre autenticación y no repudio? Un ejemplo de cada uno**

La **autenticación** verifica que una entidad (persona, equipo o proceso) es quien dice ser, antes de otorgarle acceso. Responde a la pregunta «¿quién sos?». Puede basarse en algo que se sabe (contraseña), se tiene (token, celular) o se es (huella) [4].

El **no repudio** garantiza que, una vez realizada una acción o enviado un mensaje, su autor no pueda negarlo después, porque existe una prueba verificable de que fue él. Se logra típicamente con firma digital, registros (logs) protegidos y sellado de tiempo. Responde a «¿puedo demostrar que lo hiciste vos?».

- **Ejemplo de autenticación:** al ingresar al home banking con usuario, contraseña y un código enviado al celular, el banco comprueba tu identidad.
- **Ejemplo de no repudio:** una empresa firma un contrato con firma digital (Ley 25.506); luego el firmante no puede alegar que no lo firmó, porque la firma se generó con su clave privada, vinculada a su certificado [5].

La diferencia clave: la autenticación actúa **al momento del acceso** y prueba identidad; el no repudio actúa **después del hecho** y prueba autoría ante terceros (incluso en un juicio).

- **Caso real de ransomware: organización afectada, propagación y consecuencias**

Caso: Change Healthcare (UnitedHealth Group, EE. UU.), febrero de 2024. Change Healthcare es una cámara de compensación que procesa una enorme proporción de los reclamos y pagos médicos de Estados Unidos.

Cómo ocurrió: el grupo ALPHV/BlackCat usó credenciales robadas para entrar, el 12 de febrero, a un portal de acceso remoto Citrix que **no tenía autenticación multifactor**. Desde allí se movió lateralmente por la red, robó datos y desplegó el ransomware nueve días después, el 21 de febrero [6][7].

Contención: al detectar el ataque, la compañía desconectó los sistemas de Change del resto de la red, lo que evitó que el cifrado llegara a otras entidades de UnitedHealth, pero obligó a reconstruir la plataforma casi desde cero [6].

Consecuencias:

- La plataforma de reclamos y pagos quedó detenida más de un mes; farmacias y consultorios tuvieron que operar manualmente [6][7].
- UnitedHealth reconoció haber pagado un rescate de aproximadamente USD 22 millones, aunque la filtración de datos continuó por conflictos dentro del grupo atacante [8].
- La compañía informó finalmente alrededor de 190 millones de personas afectadas, la mayor filtración de datos de salud registrada en EE. UU. [9].

Lección: un único punto de acceso remoto sin MFA, combinado con credenciales filtradas, bastó para paralizar un sector entero. Pagar el rescate no garantizó que los datos no se difundieran.

- **Diferencia entre DoS y DDoS; ¿por qué el segundo es más difícil de mitigar?**

Un ataque de **denegación de servicio (DoS)** busca agotar los recursos de un servicio (ancho de banda, CPU, memoria, conexiones) para que los usuarios legítimos no puedan usarlo, y se origina desde **una única fuente**. Un ataque **DoS distribuido (DDoS)** hace lo mismo pero desde **miles o millones de dispositivos** a la vez, normalmente una botnet de equipos infectados (PC, routers, cámaras IP) controlados por el atacante [10].

¿Por qué el DDoS es más difícil de mitigar?

- **No hay una IP que bloquear:** el tráfico llega desde una enorme cantidad de direcciones distintas, por lo que un simple filtrado por origen no sirve.
- **Volumen:** la suma del tráfico puede superar la capacidad del enlace o del servidor de la víctima, sin importar cuán bien configurado esté.
- **Tráfico que parece legítimo:** cada bot puede enviar solicitudes aparentemente normales (por ejemplo, peticiones HTTP válidas), lo que dificulta distinguirlas de usuarios reales.

- **Orígenes reales y dispersos:** los equipos son víctimas inocentes, así que bloquearlos tiene costos y rastrear al atacante real es muy complejo.

Se mitiga con servicios especializados (redes de distribución de contenido y «scrubbing centers»), limitación de tasa, filtrado en el proveedor de internet y arquitectura redundante [10].

- **Ejemplo de campaña de phishing reciente y técnicas de engaño**

Campaña de phishing que suplanta a ARCA (ex AFIP), Argentina, 2026. ARCA advirtió sobre una campaña masiva de correos que usaban su imagen oficial para intimar a los contribuyentes por deudas inexistentes o por la necesidad de «actualizar datos» para no perder servicios. Al hacer clic en el enlace no se abría un documento: se descargaba un **archivo ejecutable** con capacidad de registrar lo tipeado (keylogger) y de bloquear el acceso a los sitios oficiales de bancos [11].

Técnicas de engaño utilizadas:

- **Suplantación de identidad institucional:** logos, firmas y lenguaje formal de un organismo conocido.
- **Urgencia y miedo:** amenaza de embargos, intimaciones o suspensión de servicios para que la víctima actúe sin pensar.
- **Enlace/archivo malicioso disfrazado de documento:** el clic descarga malware en lugar de mostrar información.
- **Ingeniería social:** se apunta a la persona, no a la tecnología.

Como dato complementario, en 2026 también crece el **quishing** (phishing con códigos QR): se pegan calcomanías con un QR falso sobre el del comercio o se envían QR en «avisos» que llevan a sitios clonados de bancos y billeteras. Kaspersky reportó que este tipo de ataques creció más de cinco veces en tres meses [12].

Cómo defenderse: ARCA no usa el correo para pedir pagos ni informar embargos; los reportes se envían a phishing@arca.gob.ar [11]. Además, verificar siempre el dominio, no instalar archivos recibidos por correo y activar MFA.

- **¿Cómo puede un atacante realizar un ataque Man in the Middle en una red Wi-Fi pública? Herramientas**

En un ataque **Man in the Middle (MitM)** el atacante se interpone entre dos partes que creen comunicarse directamente, pudiendo **leer y/o modificar** el tráfico. Las redes Wi-Fi públicas (cafés, aeropuertos, hoteles) son un escenario favorable porque cualquiera puede conectarse, muchas no tienen cifrado y los usuarios confían en ellas.

Modalidades habituales (descritas a nivel conceptual):

- **Punto de acceso falso («evil twin»):** el atacante crea una red con el mismo nombre que la legítima (por ejemplo, «Cafe_WiFi_Gratis»); los

dispositivos que se conectan a ella pasan todo su tráfico por el equipo del atacante.

- **ARP spoofing/poisoning:** estando en la misma red local, el atacante envía respuestas ARP falsas para que la víctima asocie la IP del router con la MAC del atacante. Así el tráfico pasa por él.
- **DNS spoofing:** se responden consultas DNS con direcciones falsas para llevar a la víctima a sitios clonados.
- **SSL stripping:** se intenta degradar conexiones HTTPS a HTTP para ver datos en claro (mitigado por HSTS).

Herramientas conocidas: Bettercap, framework de código abierto para reconocimiento y ataques MitM sobre redes WiFi, Ethernet y Bluetooth [13]; **Ettercap**, clásica suite para MitM en redes LAN; **mitmproxy**, proxy interceptor de HTTP/HTTPS usado en pruebas de seguridad; y **Wireshark** para analizar el tráfico capturado [14]. Estas herramientas se emplean legítimamente en auditorías y pentesting con autorización; usarlas sin permiso es un delito (Ley 26.388).

Protección: usar HTTPS (y HSTS), evitar operaciones sensibles en Wi-Fi pública, usar una VPN, desactivar la conexión automática a redes abiertas, verificar certificados y preferir datos móviles. En redes propias, habilitar «aislamiento de clientes» y Dynamic ARP Inspection en equipos gestionables.

- **¿Qué diferencia hay entre sniffing y spoofing?**

Aspecto	Sniffing (rastreo)	Spoofing (suplantación)
Qué es	Captura y análisis del tráfico que circula por la red.	Falsificación de identidad (dirección IP, MAC, DNS, correo, etc.) para hacerse pasar por otro.
Naturaleza	Generalmente **pasivo**: observa sin alterar.	**Activo**: inyecta información falsa.
Objetivo	Obtener datos (credenciales, mensajes) o diagnosticar la red.	Engañar a equipos o personas, evadir filtros o desviar tráfico.
Pilar CIA afectado	Confidencialidad	Integridad / autenticidad
Ejemplo	Capturar con Wireshark credenciales enviadas por HTTP o FTP sin cifrar.	ARP spoofing, IP spoofing, DNS spoofing, correo con remitente falso.

Ambas técnicas suelen combinarse: el spoofing sirve para desviar el tráfico hacia el atacante (MitM) y el sniffing para leerlo. El sniffing también tiene usos legítimos (administración y diagnóstico de redes) [14]. La defensa común es el cifrado extremo a extremo (TLS, VPN), la segmentación y el uso de switches con protecciones de capa 2.

- **Firewall de filtrado de paquetes, stateful y NGFW: ventaja adicional de cada evolución**

Tipo	Cómo decide	Ventaja / aporte	Limitación
Filtrado de paquetes (stateless)	Examina cada paquete de forma aislada según IP origen/destino, puerto y protocolo (ACL).	Rápido, simple y barato. Es la base: permite bloquear lo que no corresponde.	No recuerda conexiones; no distingue una respuesta legítima de un paquete forjado; difícil de mantener en reglas complejas.
Stateful (inspección de estado)	Mantiene una **tabla de conexiones** (estado de TCP, etc.) y evalúa el paquete en su contexto.	Permite solo el tráfico de retorno de conexiones iniciadas desde adentro; bloquea paquetes fuera de secuencia; reglas más simples y más seguras.	Sigue trabajando en capas 3 y 4: no entiende qué aplicación o contenido viaja por un puerto abierto.
NGFW (Next-Generation Firewall)	Suma **inspección profunda de paquetes** y conciencia de aplicación y usuario.	Identifica aplicaciones (no solo puertos), integra IPS, filtrado web/URL, antimalware, inspección de TLS, control por usuario y threat intelligence.	Más costoso y exigente en recursos; la inspección TLS plantea consideraciones de privacidad y rendimiento.

Resumen de la evolución: el filtrado de paquetes aporta **control por reglas**, el stateful aporta **contexto de conexión** y el NGFW aporta **visibilidad de aplicaciones, usuarios y contenido** [15].

- ### Diferencia entre IDS e IPS, con herramientas reales

Un **IDS (Intrusion Detection System)** monitorea el tráfico o los eventos de un sistema, **detecta** actividad sospechosa y **genera alertas**, pero no bloquea por sí mismo. Se conecta de forma **pasiva** (por ejemplo, en un puerto espejo o SPAN). Un **IPS (Intrusion Prevention System)** hace la misma detección pero se ubica **en línea (inline)** en el camino del tráfico y puede **bloquear** paquetes, descartar conexiones o resetear sesiones de forma automática [16].

Característica	IDS	IPS
Ubicación	Fuera de línea (pasivo, copia del tráfico)	En línea (activo, el tráfico lo atraviesa)
Acción	Alerta y registra	Alerta, **bloquea** y registra
Riesgo	No frena el ataque; requiere respuesta humana	Un falso positivo puede cortar tráfico legítimo; puede ser punto de falla
Herramientas	**Snort** y **Suricata** en modo IDS; Zeek (análisis de red)	**Snort** y **Suricata** en modo IPS (inline); IPS integrados en NGFW

Snort (proyecto de código abierto, hoy mantenido por Cisco) y **Suricata** (motor de código abierto de la OISF) pueden funcionar tanto como IDS como IPS según cómo se desplieguen [17][18]. Ambos utilizan firmas (reglas) y, en parte, detección por anomalías.

- ### ¿Qué es TLS/SSL, por qué es importante y qué significa el candado del navegador?

TLS (Transport Layer Security) es el protocolo criptográfico que protege las comunicaciones sobre una red; **SSL (Secure Sockets Layer)** es su predecesor, hoy obsoleto y vulnerable (la versión vigente es TLS 1.3, definida en la RFC 8446) [19]. Es la base de **HTTPS**.

TLS aporta tres garantías a la web:

- **Confidencialidad:** el contenido viaja cifrado; quien intercepte el tráfico (por ejemplo, en un Wi-Fi público) no puede leerlo.
- **Integridad:** se detecta si los datos fueron modificados en tránsito.
- **Autenticación del servidor:** mediante un **certificado digital** emitido por una autoridad certificante (CA), el navegador comprueba que el sitio es realmente el dominio que dice ser.

Funcionamiento resumido: el cliente y el servidor negocian versión y algoritmos, el servidor presenta su certificado, el cliente lo valida contra las CA en las que confía, se acuerda una clave de sesión mediante intercambio de claves (efímero en TLS 1.3) y desde allí el tráfico se cifra con esa clave simétrica [19][20].

¿Qué significa el candado? Indica que la conexión con ese sitio está cifrada y que el certificado del dominio es válido y está emitido por una CA de confianza. **No significa que el sitio sea confiable o legítimo:** un sitio de phishing también puede tener candado, porque obtener un certificado para un dominio propio es sencillo y gratuito. Por eso hay que mirar el dominio completo, no solo el candado [20].

- **¿Cómo funciona una VPN y en qué situaciones la recomendarías?**

Una **VPN (Red Privada Virtual)** crea un **túnel cifrado** entre tu dispositivo y un servidor VPN (de tu empresa o de un proveedor). El cliente encapsula cada paquete dentro de otro paquete cifrado (por ejemplo, con IPsec, OpenVPN o WireGuard) y lo envía al servidor VPN; este lo descifra y lo reenvía a su destino. Para el resto de internet, el tráfico parece originarse en el servidor VPN, y quien esté en el medio (la red Wi-Fi, el proveedor de internet) solo ve tráfico cifrado hacia ese servidor [21].

Situaciones en las que la recomiendo:

- **Redes Wi-Fi públicas o no confiables** (aeropuertos, hoteles, cafés), para evitar sniffing y MitM.
- **Teletrabajo:** acceso a recursos internos de la organización (VPN de acceso remoto) y conexión segura entre sucursales (VPN sitio a sitio).
- **Privacidad frente al proveedor de internet** o a redes que monitorean el tráfico.

Limitaciones: no te protege del phishing ni del malware, y traslada la confianza al operador de la VPN (puede ver tu tráfico). Una VPN de acceso remoto debe llevar siempre MFA: varios incidentes graves (como el de Change Healthcare) empezaron por accesos remotos sin ese control [6].

- **¿Qué es la autenticación multifactor (MFA) y tres ejemplos de segundo factor?**

La **MFA** exige comprobar la identidad con **dos o más factores de categorías distintas**: algo que **sabés** (contraseña, PIN), algo que **tenés** (celular, token, llave de seguridad) y algo que **sos** (huella, rostro) [4]. Si un atacante roba la contraseña, igualmente le falta el otro factor. Cabe aclarar que dos contraseñas no son MFA: deben ser factores de distinto tipo.

Ejemplos de segundo factor:

- **Código temporal (TOTP)** generado por una app autenticadora (Google Authenticator, Microsoft Authenticator, etc.) que cambia cada 30 segundos.
- **Llave de seguridad física** (FIDO2/WebAuthn, por ejemplo YubiKey) o **passkeys**, que son resistentes al phishing.
- **Biometría** (huella o reconocimiento facial) o **notificación push** de aprobación en el celular.

El SMS también se usa, pero es el más débil (riesgo de SIM swapping e interceptación); NIST lo considera un método restringido [4]. Conviene preferir apps autenticadoras o llaves FIDO2.

- **¿Qué ventajas ofrece segmentar una red en VLANs?**

Una **VLAN (Virtual LAN, IEEE 802.1Q)** divide lógicamente una red física en varios dominios de broadcast independientes. Frente a tener todos los dispositivos en una única red plana ofrece:

- **Seguridad:** se aíslan grupos (administración, alumnos, invitados, cámaras, servidores). Si un equipo se infecta, el atacante no ve ni alcanza directamente al resto, lo que limita el movimiento lateral.
- **Control del tráfico entre segmentos:** el tráfico entre VLANs debe pasar por un router o firewall, donde se aplican ACL y reglas de inspección.
- **Menor dominio de broadcast:** menos tráfico innecesario y mejor rendimiento.
- **Menor superficie de ataques de capa 2** (como ARP spoofing o sniffing), que quedan confinados a la VLAN.
- **Flexibilidad y administración:** se agrupan usuarios por función y no por ubicación física; se simplifica aplicar políticas.
- **Cumplimiento normativo:** estándares como PCI DSS exigen segmentar el entorno que maneja datos de tarjetas [22].

Ejemplo: una escuela con VLAN 10 (administración), VLAN 20 (docentes), VLAN 30 (alumnos), VLAN 40 (WiFi invitados) y VLAN 50 (servidores), con un firewall que solo permite a docentes acceder a los servidores necesarios.

- **¿Qué es una DMZ y por qué no ubicar allí un servidor de base de datos sensible?**

Una **DMZ (zona desmilitarizada)** es una subred intermedia, separada tanto de internet como de la red interna, donde se colocan los servicios que **deben ser accesibles desde el exterior** (servidor web, correo, DNS público, proxy inverso). Se implementa con un firewall que tiene tres interfaces (internet, DMZ, LAN) o con dos firewalls en cascada [15].

Las reglas típicas son: internet puede llegar solo a los puertos necesarios de la DMZ; la DMZ **no puede iniciar** conexiones libres hacia la LAN; y la LAN puede acceder a la DMZ para administración.

¿Por qué no poner allí la base de datos con información sensible?

- Los servidores de la DMZ están **expuestos** y se asumen como los primeros en ser atacados o comprometidos; una base de datos allí heredaría esa exposición.
- Si un atacante toma el servidor web, tendría **acceso directo y cercano** a los datos sensibles. En cambio, con la base en la red interna, aún tiene que superar un segundo firewall.
- Se violaría el principio de **defensa en profundidad** y de **mínimo privilegio**.

Diseño correcto: el servidor web (DMZ) consulta a la base de datos ubicada en una **red interna o de datos** protegida, a través de una regla del firewall que permita únicamente el puerto y la IP necesarios (por ejemplo, TCP 3306/5432 solo desde el servidor de aplicación) y con credenciales de mínimo privilegio.

- **¿Qué es un ataque de «VLAN hopping» y cómo se previene?**

El **VLAN hopping** es un ataque que permite a un atacante enviar tráfico a una VLAN a la que no pertenece, eludiendo la segmentación. Existen dos variantes principales [23]:

- **Switch spoofing:** el atacante hace que su equipo se comporte como un switch y negocia un enlace troncal (trunk) mediante el protocolo DTP (Dynamic Trunking Protocol), si el puerto está en modo «dynamic auto/desirable». Una vez en trunk, accede al tráfico de todas las VLAN.
- **Doble etiquetado (double tagging):** el atacante, conectado a la VLAN nativa del trunk, envía tramas con **dos etiquetas 802.1Q**. El primer switch elimina la etiqueta externa (la de la VLAN nativa) y reenvía la trama con la etiqueta interna, que la entrega en la VLAN víctima. Es un ataque unidireccional (no recibe respuesta).

Prevención:

- Configurar los puertos de usuario de forma explícita como **access** (`switchport mode access`) y desactivar la negociación DTP (`switchport nonegotiate`).

- Configurar los trunks de forma manual y **permitir solo las VLAN necesarias** (`switchport trunk allowed vlan`).
- Cambiar la **VLAN nativa** a una VLAN sin uso (no la VLAN 1) y no asignar usuarios a ella; opcionalmente etiquetar también la VLAN nativa.
- Mover los puertos sin uso a una VLAN «agujero negro» y deshabilitarlos (`shutdown`).
- Aplicar port security, 802.1X y mantener el firmware actualizado.

- **Normativa o estándar de seguridad de la información: ¿qué establece?**

Se describen dos referencias principales:

ISO/IEC 27001:2022 es la norma internacional que especifica los requisitos para establecer, implementar, mantener y mejorar un **Sistema de Gestión de Seguridad de la Información (SGSI)**. Se basa en la **gestión de riesgos**: la organización define el alcance, identifica activos y riesgos, y selecciona controles proporcionales. Incluye el cuerpo principal (contexto, liderazgo, planificación, soporte, operación, evaluación y mejora continua, ciclo PDCA) y un **Anexo A** con 93 controles agrupados en cuatro temas: organizacionales, de personas, físicos y tecnológicos. Es certificable por entidades externas acreditadas [24].

NIST Cybersecurity Framework (CSF) 2.0 (2024) es un marco voluntario del Instituto Nacional de Estándares y Tecnología de EE. UU. que ordena la gestión del riesgo de ciberseguridad en seis funciones: **Gobernar (Govern), Identificar, Proteger, Detectar, Responder y Recuperar**. No exige controles específicos sino resultados deseados, y es aplicable a organizaciones de cualquier tamaño y sector [1].

Diferencia: ISO 27001 es una norma **certificable** que exige un sistema de gestión documentado; el NIST CSF es un **marco de referencia** flexible, ideal para evaluar madurez y comunicar el riesgo.

- **¿Qué es un CSIRT/CERT? ¿Existe uno en Argentina y qué funciones cumple?**

Un **CSIRT (Computer Security Incident Response Team)**, también llamado **CERT (Computer Emergency Response Team)**, es un equipo especializado que recibe reportes de incidentes de seguridad, los analiza, coordina la respuesta y la recuperación, emite alertas y avisos de vulnerabilidades y difunde buenas prácticas [40]. Puede ser nacional, sectorial o de una organización.

En Argentina existe el CERT.ar (Centro Nacional de Respuesta a Incidentes Informáticos). Funciona como CSIRT nacional: recibe y gestiona incidentes del sector público nacional y de las infraestructuras críticas, emite alertas y recomendaciones, y coordina con otros equipos de respuesta. Históricamente dependía de la Dirección Nacional de Ciberseguridad [25].

Novedad institucional: a través del DNU 941/2025 (publicado el 2 de enero de 2026) se creó el **Centro Nacional de Ciberseguridad (CNC)** como autoridad nacional en la materia, organismo descentralizado bajo la Secretaría de Innovación, Ciencia y Tecnología de la Jefatura de Gabinete. Entre sus funciones está el monitoreo y respuesta de incidentes del Sector Público Nacional y de infraestructuras críticas, y la **dirección del CERT.ar** [25][26]. Cabe aclarar que su diseño y funcionamiento han sido objeto de cuestionamientos y pedidos de informes en el Congreso [27].

Además, se ha propuesto en provincias (por ejemplo, un proyecto de ley de Mendoza de 2026) crear CSIRT y SOC provinciales [28].

- **¿Por qué no apagar un equipo comprometido antes de analizarlo? Relación con la cadena de custodia**

Al apagar un equipo se **pierde la evidencia volátil**, que existe solo mientras hay energía. La RFC 3227 (guía para recolección de evidencia) y la guía NIST SP 800-86 establecen que la recolección debe seguir el **orden de volatilidad**, de lo más efímero a lo más persistente [29][30]:

- Registros y caché del procesador; **memoria RAM** (procesos en ejecución, claves de cifrado, malware residente en memoria, comandos recientes).
- **Conexiones de red activas**, tabla ARP, tabla de rutas.
- Procesos, sesiones abiertas y sistemas de archivos temporales.
- Disco, logs y backups (persistentes).

Apagar el equipo borra la RAM; además puede **activar mecanismos del propio malware** (por ejemplo, cifrar o borrar datos al reiniciar), alterar fechas de archivos o dejar el disco con cambios que invaliden la prueba. Si el equipo tiene el disco cifrado, apagarlo puede hacer perder el acceso a los datos.

Qué se recomienda: aislarlo de la red (desconectar el cable o desactivar el Wi-Fi, sin apagar), documentar lo que se observa en pantalla, capturar la memoria y evidencia volátil con herramientas forenses confiables y luego hacer una **imagen forense** del disco, trabajando sobre copias y con bloqueadores de escritura.

Relación con la cadena de custodia: es el registro documentado y continuo de **quién** recolectó, manipuló, transfirió o analizó cada evidencia, **cuándo, dónde y cómo**, para demostrar que no fue alterada. Para ello se calculan **hashes** (SHA-256) de las imágenes antes y después, se etiquetan y precintan los soportes, y se registra cada traspaso. Apagar o modificar el equipo sin criterio forense rompe la integridad de la evidencia y puede hacer que **no sea admisible** en un proceso judicial o disciplinario [29][30].

- **En nuestro país, ¿hay reglamentaciones? ¿Cuáles?**

Sí. Argentina no tiene todavía una única ley integral de ciberseguridad vigente para el sector privado, pero cuenta con un conjunto de normas. Las principales son:

Norma	Qué regula
Ley 26.388 (2008)	Reforma el Código Penal e incorpora los **delitos informáticos**: acceso ilegítimo a sistemas, daño informático, interceptación de comunicaciones, fraude informático, violación de secretos y correspondencia electrónica, entre otros [31].
Ley 25.326 (2000) y decreto 1558/2001	**Protección de datos personales** (habeas data). Autoridad de control: Agencia de Acceso a la Información Pública (AAIP). Exige medidas de seguridad y confidencialidad sobre las bases de datos.
Ley 27.411 (2017)	Aprueba la adhesión al **Convenio de Budapest sobre Ciberdelito** (cooperación internacional y estándares penales y procesales).
Ley 26.904 (2013)	Incorpora el delito de **grooming** al Código Penal.
Ley 25.506 (2001)	**Firma digital** y su validez jurídica (relacionada con el no repudio).
Ley 27.275 (2016)	Derecho de acceso a la información pública.
Normativa del sector público	Comité de Ciberseguridad (Decreto 577/2017), Programa ICIC (Res. 580/2011), Estrategias Nacionales de Ciberseguridad, requisitos mínimos de seguridad para organismos nacionales y **DNU 941/2025**, que crea el Centro Nacional de Ciberseguridad [25][26][31].

Norma	Qué regula
Sector financiero (BCRA)	Comunicaciones del Banco Central sobre requisitos mínimos de gestión de riesgos de tecnología y seguridad de la información, y reporte de incidentes cibernéticos para entidades financieras (por ejemplo, Com. «A» 4609 y «A» 7266). Conviene verificar el texto ordenado vigente.

Proyectos en trámite (2026): existe un proyecto de **Ley de Ciberseguridad Nacional** en la Cámara de Diputados que crearía el Centro Nacional de Ciberseguridad como autoridad rectora y mantendría vigentes las leyes 25.326, 26.388 y 27.411, entre otras [32]; y la provincia de Mendoza anunció y envió a su Legislatura un proyecto provincial de ciberseguridad [28][33]. Son **proyectos**, no leyes vigentes, según las fuentes consultadas.

- ### Empresas locales que sufrieron ataques cibernéticos: situación y resolución

Caso 1: Telecom Argentina (julio de 2020, ransomware). El sábado 19 de julio, la compañía detectó un ransomware que afectó aproximadamente el 5 % de sus equipos informáticos y que buscaba cifrar archivos para luego pedir rescate en criptomonedas. Algunos medios lo atribuyeron al grupo REvil y mencionaron un pedido de unos USD 7,5 millones en Monero; la empresa no confirmó el monto.

Resolución: según la empresa, los sistemas de alerta detectaron el intento y se **aislaron los archivos afectados de inmediato**; junto con socios como Deloitte, se **bloqueó el acceso a internet y se limitó el acceso por VPN**. El incidente se contuvo en pocas horas, **sin acceder a la demanda del**

atacante, y Telecom informó que no se vieron afectados los servicios ni las bases de datos ni clientes corporativos [34].

Caso 2: Mercado Libre (marzo de 2022, acceso no autorizado). La empresa confirmó que parte de su código fuente y datos de unos 300.000 usuarios (de unos 140 millones activos) habían sido accedidos sin autorización. El ataque fue atribuido al grupo **Lapsus$**. La compañía informó que no se obtuvieron contraseñas, saldos, inversiones ni datos de tarjetas, y que no había evidencia de que la infraestructura hubiera sido vulnerada [35].

Resolución: Mercado Libre **activó sus protocolos de seguridad**, realizó un análisis exhaustivo, informó públicamente a los usuarios y anunció medidas estrictas para evitar nuevos incidentes [35].

Caso reciente (julio de 2026, sin confirmar): el grupo de ransomware The Gentlemen incluyó a Mercado Libre en su sitio de filtraciones de la dark web y amenazó con publicar datos. Según los medios consultados, las plataformas siguieron operativas y la empresa no había confirmado el alcance. SOCRadar recomendó tratar el listado con escepticismo hasta que haya evidencia corroborante [36][37]. Por eso se lo menciona como **reclamo del atacante**, no como incidente comprobado.

Aprendizaje común: en ambos casos confirmados, la **detección temprana, el aislamiento y la comunicación transparente** limitaron el daño. Telecom además evitó el pago del rescate gracias a la contención.

- **¿Cómo se realiza la configuración de seguridad en una red?**

La configuración segura de una red se hace por capas («defensa en profundidad») y siguiendo un proceso ordenado. Un esquema general, alineado con el NIST CSF [1] y SP 800-41 [15]:

- **Relevamiento y análisis de riesgos.** Inventariar equipos, servicios y datos; identificar amenazas y definir qué se debe proteger primero (ISO 27001 [24]).

- **Diseño y segmentación.** Dividir la red en VLAN/subredes según función (usuarios, invitados, servidores, administración, IoT), ubicar los servicios públicos en una DMZ y los datos sensibles en zonas internas protegidas.

- **Filtrado y control de tráfico.** Firewall con política de **denegar por defecto** y permitir solo lo necesario (mínimo privilegio), ACL entre segmentos, y reglas bien documentadas. Ejemplo de política base en Linux con nftables/iptables:

```
ipt
abl
es
-P
INP
UT
DRO
P
```

```
ipt
abl
es
-P
FOR
WAR
D
DRO
P
iptables -A INPUT -i lo -j ACCEPT
iptables -A INPUT -m conntrack --ctstate
ESTABLISHED,RELATED -j ACCEPT iptables -A INPUT -p
tcp --dport 22 -s 192.168.10.0/24 -j ACCEPT
```

- **Endurecimiento (hardening) de equipos de red.** Cambiar credenciales por defecto, usar contraseñas robustas y MFA para administración, deshabilitar servicios y puertos no usados, administrar por SSH (no Telnet) y HTTPS, actualizar firmware y parches. En switches: port security, DHCP snooping, Dynamic ARP Inspection, protección contra VLAN hopping y STP (BPDU guard).
- **Control de acceso.** Autenticación con 802.1X o WPA2/WPA3-Enterprise, cuentas individuales (no compartidas), roles de mínimo privilegio y MFA, especialmente en accesos remotos y VPN.
- **Cifrado.** TLS en servicios, VPN para accesos remotos y entre sedes (IPsec/WireGuard [21]), Wi-Fi con WPA3/WPA2-AES.
- **Monitoreo y detección.** Centralizar logs (syslog/SIEM), desplegar IDS/IPS (Snort, Suricata [17][18]), alertas y sincronización horaria (NTP) para poder correlacionar eventos.
- **Respaldo y continuidad.** Copias de seguridad con regla 3-2-1 (tres copias, dos medios, una fuera de línea), probadas periódicamente; es la mejor defensa frente al ransomware.
- **Concientización y procedimientos.** Capacitación contra phishing, políticas escritas y un plan de respuesta a incidentes [40].
- **Pruebas y mejora continua.** Escaneo de vulnerabilidades, pruebas de penetración, revisión periódica de reglas y auditorías.

- ### ¿Cómo configurar la seguridad de tu conexión a internet?

Pasos prácticos para una conexión hogareña o de una pequeña oficina:

En el router / módem

- **Cambiar la contraseña de administración** del router (la que viene de fábrica suele ser conocida) y, si es posible, el usuario. Se accede por la IP del router (por ejemplo, 192.168.0.1 o 192.168.1.1).
- **Wi-Fi con cifrado WPA3** o, si el equipo no lo soporta, **WPA2-AES (CCMP)**. Evitar WEP, WPA y redes abiertas.
- **Contraseña Wi-Fi larga** (idealmente una frase de 14 o más caracteres) y un nombre de red (SSID) que no revele datos personales ni el modelo del equipo.

- **Desactivar WPS** y, si no se usa, **UPnP** y la **administración remota** desde internet.
- **Red de invitados** separada para visitas y para dispositivos IoT (TV, cámaras, asistentes), para que no vean tus computadoras.
- **Actualizar el firmware** del router y activar las actualizaciones automáticas si existen. Cambiar o reemplazar equipos que ya no reciben soporte.
- Activar el **firewall** del router y revisar periódicamente qué dispositivos están conectados.
- Opcional: usar **DNS seguro** (DNS sobre HTTPS/TLS) con filtrado de sitios maliciosos.

En los dispositivos

- Mantener actualizados el sistema operativo, el navegador y las aplicaciones; usar antivirus/antimalware y el firewall del sistema.
- Usar **cuentas sin privilegios de administrador** para el uso diario.

- **Gestor de contraseñas** con claves únicas y **MFA** en correo, bancos y redes sociales [4].
- Cifrar el disco (BitLocker, FileVault) y hacer **copias de seguridad** periódicas (regla 3-2-1).

En el uso diario

- Verificar HTTPS y el dominio completo antes de ingresar datos; desconfiar de enlaces, QR y archivos inesperados [11][12].
- En redes públicas, evitar operaciones sensibles o usar **VPN** [21].
- Ante un fraude, conservar capturas y datos y denunciarlo (por ejemplo, ante la fiscalía especializada en ciberdelitos o la entidad bancaria).

Las recomendaciones de CISA «Secure Our World» y de Argentina.gob.ar («Convos en la web») resumen buenas prácticas para usuarios [38][39].

- NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. National Institute of Standards and Technology, 2024. https://www.nist.gov/cyberframework
- Mercado.com.ar. «Argentina se ubica cuarta en el ranking de ataques de ransomware en Latinoamérica» (informe «Ransomware en LATAM – Primer Semestre de 2025», SCILabs/Scitum). https://mercado.com.ar/ruta- HYPERLINK "https://mercado.com.ar/ruta-digital/ar"digital/ar gentina-se-ubica-cuarta-en-el-ranking-de-ataques-de-ransomware-en-latinoamerica
- ISO/IEC. *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection - Information security management systems - Requirements*. https://www.iso.org/standard/27001.html (tríada CIA: definiciones de ISO/IEC 27000).
- NIST. *SP 800-63B Digital Identity Guidelines: Authentication and Lifecycle Management*. https://pages.nist.gov/800-63-3/sp800-63b.html

- Infoleg. Ley 25.506 de Firma Digital (Argentina). https://www.infoleg.gob.ar
- Healthcare Dive. «UnitedHealth: Change Healthcare attack, compromised credentials, no MFA» y notas de testimonio de Andrew Witty. https://www.healthcaredive.com/news/change-healthcare-compromised-credentials-no-mfa/714824/ ; https://www.healthcaredive.com/news/unitedhealth-change-attack-tech-takeaways/715274/
- TechTarget. «Change Healthcare breached via Citrix portal with no MFA». https://www.techtarget.com/cybersecuri HYPERLINK "https://www.techtarget.com/cybersecurity/news/366582824/Change-Healthcare-breached-via-Citrix-portal-with-no-MFA"ty/news/366582824/Change-Healthcare-breached-via-Citrix-portal-with-no-MFA
- SecureBlink. «United Health's Change Healthcare ransomware attack leaked medical records». https://www.secur eblink.com/cyber-security-news/united-health-s-change-healthcare-ransomware-attack-leaked-medical-records
- CyberInsider. «UnitedHealth: Change Healthcare breach affected approximately 190 million individuals». https://cyberinsider.com/ (nota sobre el alcance de la filtración).
- Cloudflare Learning Center. «What is a DDoS attack?». https://www.cloudflare.com/learning/ddos/what-is-a-ddos- HYPERLINK "https://www.cloudflare.com/learning/ddos/what-is-a-ddos-attack/"attack/
- iProfesional. «ARCA alertó sobre una peligrosa estafa virtual que circula por mail», 2026. https://www.iprofesional.com/actualidad/449888-arca-alerto-sobre-una-peligrosa-estafa- HYPERLINK "https://www.iprofesional.com/actualidad/449888-arca-alerto-sobre-una-peligrosa-estafa-virtual"virtual
- iProfesional. «El robo silencioso detrás del pago con QR: así hacen los hackers para vaciarte la cuenta» (informe de Kaspersky sobre quishing), 2026. https://www.iprofesional.com/actualidad/446295-robo-silencioso-detras-pa go-con-qr-asi-hacen-hackers-para-vaciarte-cuenta
- Bettercap. Documentación oficial del proyecto. https://www.bettercap.org
- Wireshark Foundation. Documentación oficial. https://www.wireshark.org
- NIST. *SP 800-41 Rev. 1 Guidelines on Firewalls and Firewall Policy*. 2009. https://csrc.nist.gov/pubs/sp/800/41/r1/final
- NIST. *SP 800-94 Guide to Intrusion Detection and Prevention Systems (IDPS)*. 2007. https://csrc.nist.gov/pubs/sp/800/94/final
- Snort. Sitio oficial (Cisco). https://www.snort.org
- Suricata. Open Information Security Foundation (OISF). https://suricata.io

- Rescorla, E. *RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3*. IETF, 2018. https://www.rfc-editor.org/rfc/rfc8446
- MDN Web Docs. «Transport Layer Security (TLS)». https://developer.mozilla.org/es/docs/Web/Security/Transport_Layer_Security
- NIST. *SP 800-77 Rev. 1 Guide to IPsec VPNs*. 2020. https://csrc.nist.gov/pubs/sp/800/77/r1/final
- PCI Security Standards Council. *PCI DSS* (requisitos de segmentación de red). https://www.pcisecuritystandards.org
- Cisco Systems. «VLAN Security White Paper» y guías de seguridad de capa 2 (DTP, VLAN nativa, double tagging). https://www.cisco.com
- ISO/IEC 27001:2022 (ver referencia 3), Anexo A: 93 controles en cuatro temas.

- DPL News. «Argentina crea el Centro Nacional de Ciberseguridad como parte de los cambios en ley de Inteligencia» (DNU 941/2025). https://dplnews.com/argentina-crea-el-centro-nacional-de-ciberseguridad-cambios-ley-de- HYPERLINK "https://dplnews.com/argentina-crea-el-centro-nacional-de-ciberseguridad-cambios-ley-de-inteligencia/"inteligencia/
- MobileTime. «Argentina crea el Centro Nacional de Ciberseguridad (CNC)», enero de 2026. https://mobiletime.la/?p=809304 ; y Defonline. «Centro Nacional de Ciberseguridad: cómo afecta a la SIDE y quiénes estarán a cargo». https://defonline.com.ar/seguridad/centro-nacional-de-ciberseguridad-como-afecta-a- HYPERLINK "https://defonline.com.ar/seguridad/centro-nacional-de-ciberseguridad-como-afecta-a-la-side-y-quienes-estaran-a-cargo/"l HYPERLINK "https://defonline.com.ar/seguridad/centro-nacional-de-ciberseguridad-como-afecta-a-la-side-y-quienes-estaran-a-cargo/"a-side-y-quienes-estaran-a-cargo/
- Honorable Cámara de Diputados de la Nación. Proyecto de resolución (pedido de informes) sobre el Centro Nacional de Ciberseguridad, 2026. https://rest.hcdn.gob.ar/web/proyectos/292354/adjuntos/106065
- Los Andes. «Alfredo Cornejo enviará a la Legislatura un proyecto de ley de ciberseguridad», 4 de junio de 2026. https://www.losandes.com.ar/politica/alfredo-cornejo-enviara-la-legislatura-un-proyecto-ley-ciberseguridad-que- HYPERLINK "https://www.losandes.com.ar/politica/alfredo-cornejo-enviara-la-legislatura-un-proyecto-ley-ciberseguridad-que-s"s e-trata-n5993595
- IETF. *RFC 3227: Guidelines for Evidence Collection and Archiving*. 2002. https://www.rfc-HYPERLINK "https://www.rfc-editor.org/rfc/rfc3227"editor.org/rfc/rfc3227
- NIST. *SP 800-86 Guide to Integrating Forensic Techniques into Incident Response*. 2006. https://csrc.nist.gov/pubs/sp/800/86/final
- Consejo de Europa (Octopus). «Argentina - Status regarding Budapest Convention» (Ley 26.388, Ley 25.326, Ley 25.506). https://www.coe.int/en/web/octopus/-/argentina
- Honorable Cámara de Diputados de la Nación. Proyecto de «Ley de Ciberseguridad Nacional y creación del Centro Nacional de Ciberseguridad», 2026.

https://rest.hcdn.gob.ar/web/tramites- HYPERLINK "https://rest.hcdn.gob.ar/web/tramites-parlamentarios/render/adjunto/6a8f0945decf0.pdf"parlamentarios/render/adjunto/6a8f0945decf0.pdf

- El Sol. «El Gobierno envió a la Legislatura un proyecto de Ley de Ciberseguridad» (Mendoza), 2026. https://www.elsol.com.ar/?p=2233255
- DPL News. «Telecom Argentina confirmó que ciberataque a sus equipos no afectó los servicios ni las bases de datos». https://dplnews.com/?p=63298
- El Dínamo. «Todo lo que se sabe del hackeo que afectó a usuarios de Mercado Libre», 8 de marzo de 2022. https://www.eldinamo.cl/mundo/2022/03/08/todo-lo-que-se-sabe-del-hackeo-que-afecto-a-usuarios-de-mercado- HYPERLINK "https://www.eldinamo.cl/mundo/2022/03/08/todo-lo-que-se-sabe-del-hackeo-que-afecto-a-usuarios-de-mercado-libre/"libre/
- Escudo Digital. «Mercado Libre, afectada por un ataque de ransomware», 2026. https://www.escudodigital.com/ciberseguridad/mercado-libre-afectada-por-un-ataque-de- HYPERLINK "https://www.escudodigital.com/ciberseguridad/mercado-libre-afectada-por-un-ataque-de-ransomware.html"ransomware.html
- SOCRadar. «Mercado Libre Data Breach (alleged)», julio de 2026. https://socradar.io/blog/data-breach/mercado-libre-thegentlemen-ransomware- HYPERLINK "https://socradar.io/blog/data-breach/mercado-libre-thegentlemen-ransomware-2026/"2026/
- CISA. «Secure Our World». https://www.cisa.gov/secure-our- HYPERLINK "https://www.cisa.gov/secure-our-world"world
- Argentina.gob.ar. «Con vos en la web: Phishing». https://www.argentina.gob.ar/justicia/convosenlaweb/situaciones/phishing
- NIST. *SP 800-61 Computer Security Incident Handling Guide*. https://csrc.nist.gov/pubs/sp/800/61/r2/final